ESPECIFICAÇÃO TÉCNICA DE ARQUITETURA

Plataforma de Resiliência Defensiva & Security Testing

PROJETO	CLASSIFICAÇÃO	VERSÃO	AUTOR
SARR-Core Engine	Uso Defensivo / Audit	1.2.0-FINAL	Security Engineering

1. SUMÁRIO EXECUTIVO & CONCEITO OFENSIVO-DEFENSIVO

Esta especificação define a arquitetura e os requisitos funcionais de uma solução integrada de **Segurança Ofensiva Ética (Purple Teaming)**. O sistema adota a filosofia de testar ativamente a infraestrutura por meio de vetores de simulação controlados, permitindo identificar vulnerabilidades de superfície, validar mecanismos de detecção em tempo real e acionar contramedidas automáticas antes de explorações maliciosas reais.

> **Diretriz Fundamental de Operação**
>
> A plataforma opera sob o modelo *Continuous Validation & Automated Mitigation*. Nenhum módulo ofensivo é executado sem validação prévia de escopo, travas automáticas de segurança (*kill-switches*) e registro imutável em trilhas de auditoria para conformidade corporativa.

2. ESCOPO DOS VETORES DE SIMULAÇÃO E AUDITORIA

A. Redes Sem Fio (Wi-Fi 802.11)

- **Mapeamento Ativo/Passivo:** Captura de BSSIDs, SSIDs, canais e níveis RSSI.
- **Auditoria de Handshake:** Validação da robustez de trocas WPA2/WPA3.
- **Detecção de Rogue APs:** Identificação de pontos de acesso falsos (Evil Twin).
- **Management Frame Protection:** Teste de resiliência a desautenticação (802.11w).

B. Bluetooth & BLE (Low Energy)

- **Discovery & Profile GATT:** Mapeamento de serviços expostos e atributos.
- **Pairing & Bonding Security:** Análise do processo de troca de chaves.
- **BLE Advertisement Flood:** Validação de resiliência a solicitações em massa.
- **IoT Enumeration:** Identificação de periféricos e wearables vulneráveis.

C. Rádio Frequência & SDR

- **Análise Espectral:** Leitura das faixas 315/433/868/915 MHz e 2.4 GHz.
- **Replay Attack Defense:** Verificação de uso de *Rolling Codes*.
- **Signal Jamming Detection:** Identificação de picos de ruído e interferência.
- **Sub-GHz Protocol Audit:** Inspeção de pacotes não criptografados.

D. Resiliência a Carga (DDoS L4/L7)

- **SYN/UDP Flood (L4):** Teste de suporte a SYN Cookies e backlog.
- **HTTP/S Stress Testing (L7):** Avaliação de variação de RTT sob alta concorrência.
- **Slowloris Simulation:** Teste de esgotamento de conexões abertas.
- **Circuit Breaker:** Interrupção automática ao atingir limites de latência.

3. VETORES ADICIONAIS E INOVAÇÕES ARQUITETURAIS

Além dos vetores tradicionais sem fio e de estresse de aplicação, o ecossistema incorpora módulos para inspeção de redes de automação, manipulação de tráfego interno e modelos preditivos baseados em inteligência artificial.

Módulo / Vetor	Escopo Técnico e Funcionalidades	Mecanismo Defensivo Associado
Zigbee & Z-Wave	Inspeção de pacotes em redes Mesh de automação residencial e industrial (868/915 MHz e 2.4 GHz).	Identificação de nós não autorizados e forçamento de re-keying em redes IoT.
MitM & ARP Spoofing	Simulação de envenenamento de tabela ARP e interceptação de tráfego em segmento LAN local.	Habilitação remota de Dynamic ARP Inspection (DAI) e alertas de MAC duplicado.
DNS Sinkhole & Spoof	Captura de requisições DNS para domínios de comando e controle (C2) simulados.	Redirecionamento automático de tráfego malicioso para ambiente Sandbox isolado.
Motor Preditivo IA	Análise comportamental de séries temporais de tráfego via modelos de detecção de anomalias.	Ajuste dinâmico de regras de Firewall e rate-limiting prévio antes da saturação.

4. COMPONENTES DA ENGINE DEFENSIVA (PURPLE TEAMING)

Análise de Métricas em Tempo Real

Coleta contínua de telemetria do sistema operacional e placas de rede: utilização de CPU/RAM, conexões concorrentes por segundo (CPS), pacotes descartados (drop rate) e variações de RTT.

Mitigação Automática de Resposta

Injeção dinâmica de regras em firewalls locais (`iptables`/`nftables`), envio de requisições via API para WAFs e emissão de ordens de isolamento de portas em switches gerenciáveis.

5. REQUISITOS DE SEGURANÇA, GOVERNANÇA E TRAVA DE EMERGÊNCIA

Como a plataforma executa rotinas de alta densidade de tráfego e interações de baixo nível em rádio e rede, os controles de contenção são ativados por padrão no núcleo da aplicação.

System Kill-Switch (Circuit Breaker)

Monitoramento de limiares críticos. Caso a latência da aplicação testada ultrapasse **1500ms** ou a taxa de erros HTTP 5xx exceda **5%**, a suíte de testes é interrompida imediatamente.

Validação de Escopo e Assinatura

Cada execução exige a presença de um arquivo de licença e escopo delimitado (`scope.json`). Alvos fora do bloco CIDR ou BSSIDs não autorizados são bloqueados antes do envio de pacotes.

6. CASOS DE USO DO SISTEMA (USE CASES)

UC-01: Auditoria Wi-Fi e Rogue AP

Ator: Analista de Segurança / Bot Operacional

Fluxo: O módulo executa varredura passiva de 802.11 no ambiente, mapeia BSSIDs visíveis e compara com a lista branca de APs corporativos autorizados. Se um Evil Twin for identificado, gera alerta imediato para o SIEM.

UC-02: Mapeamento de Atributos BLE IoT

Ator: Auditor de Dispositivos Medtech / IoT

Fluxo: Varredura de dispositivos Bluetooth Low Energy nas proximidades, enumeração da árvore de serviços GATT e verificação de atributos sem exigência de autenticação ou criptografia no emparelhamento.

UC-03: Teste de Carga L7 com Circuit Breaker

Ator: Engenheiro de Confiabilidade (SRE)

Fluxo: Simulação progressiva de requisições HTTP/S em endpoints críticos. O monitor mede a resposta e ativa o Kill-Switch assim que o RTT ultrapassar o limite seguro, prevenindo indisponibilidade não planejada.

UC-04: Mitigação Ativa e Isolamento LAN

Ator: Engine Defensiva Automática

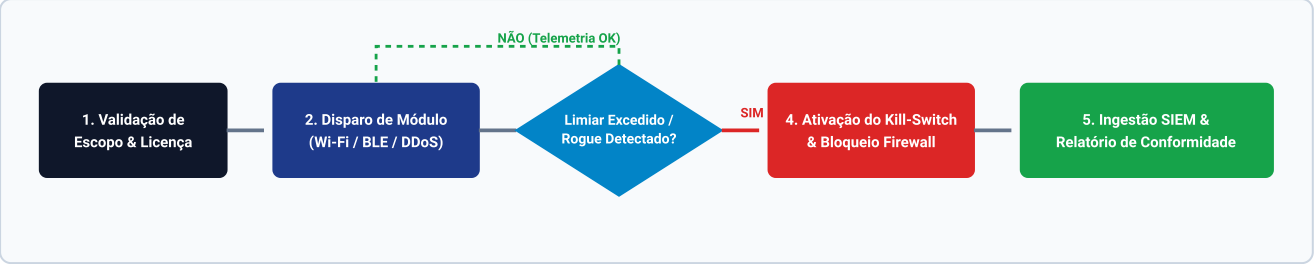
Fluxo: Ao detectar um ataque de envenenamento ARP na rede local, a engine defensiva injeta regras no firewall local (`nftables`) e aciona webhook para isolamento da porta do switch correspondente.

7. MATRIZ DE MÉTRICAS E CRITÉRIOS DE ACEITAÇÃO DE SEGURANÇA

Vetor de Teste	Métrica Chave (KPI)	Limiar Aceitável	Ação Defensiva Requerida
Wi-Fi Handshake	Resistência do Dicionário	> 12 caracteres (Complexa)	Forçar troca de credencial e isolamento VLAN.
BLE GATT Service	Acesso não autenticado	0 Serviços Críticos Abertos	Reconfigurar parm `Encryption Required`.
DDoS L7 (HTTP)	Tempo de Resposta (RTT)	< 400ms em pico de carga	Ativar Rate Limiting dinâmico no WAF.
RF Replay Attack	Validação de Replay	Rejeição de Token Duplicado	Migrar protocolo para Rolling Code / AES-128.

8. FLUXOGRAMA TÉCNICO DE EXECUÇÃO E MITIGAÇÃO

O diagrama abaixo descreve o ciclo de vida completo de uma operação no sistema: desde a validação de licença/escopo até a execução do módulo de auditoria, análise preditiva de anomalia e acionamento de mitigação defensiva.



9. ROADMAP DE IMPLEMENTAÇÃO E PRÓXIMAS ETAPAS

Com este documento de arquitetura e casos de uso formalizados, o fluxo de desenvolvimento avançará pelas seguintes fases disciplinadas:

1. **Criação da Skill do Agente:** Configuração da persona e diretrizes de codificação segura.
2. **Especificação de APIs e Estrutura de Dados:** Detalhamento dos schemas JSON, payloads e CLI.
3. **Criação dos Prompts de Geração de Código:** Gabaritos de engenharia de prompt para módulos em Python/Go.
4. **Desenvolvimento do MVP do Core Engine:** Implementação do barramento de eventos e travas de segurança.

> **Conclusão da Etapa de Concepção**
> A documentação agora possui a maturidade necessária para guiar o desenvolvimento do ecossistema sem ambiguidades técnicas ou riscos de escopo.